



SafeNode API and Integration Guide

Integration reference for authentication, vault sync, passkeys, devices, billing, webhooks, and native clients.

Document version: 2026-07-27

Product: Safenode

Classification: Internal / customer-safe where noted

API conventions

- Production base URL: <https://api.safe-node.app>
- Web frontend: <https://safe-node.app>
- Use HTTPS in all non-local environments.
- Send JSON with explicit content type; respect validation errors and rate-limit responses.
- Never log Authorization headers, cookies, passwords, recovery material, PRF output, or vault plaintext.

Authentication and protected access

Area	Endpoint family	Notes
Session	/api/auth/*	Login/signup, email verification, session identity
Vault	/api/auth/vault/*	Encrypted blob sync; requires auth and registered device
Passkeys	/api/passkeys/*	WebAuthn options, assertions, PRF wrap metadata
Devices	/api/devices/*	Registration, limits, re-approval, reclaim workflows
Teams	/api/teams/*	Team membership, vault metadata, shared access controls
Billing	/api/billing/*	Checkout, limits, portal, Paddle webhook

Passkey integration

- Web clients must use the canonical origin and RP ID configuration.
- Native clients must use platform-specific association and Credential Manager/WebAuthn configuration.
- PRF enrollment happens only after a successful password/recovery/another-passkey unlock with the vault key in memory.
- If PRF is unavailable, present the password or recovery-kit fallback honestly.
- Treat WebAuthn errors as user-actionable states, not generic server failures.

Billing integration

- Frontend selects a plan alias or provider price ID for the active billing provider.
- Backend resolves aliases against the active provider only.
- Paddle webhooks require a valid signature and are idempotent by event ID.
- Price IDs determine plan and billing cadence; current period dates determine renewal timing.
- Use Paddle sandbox events for integration tests and never replay fabricated signatures against production.

Error handling

Status	Meaning	Client action
400	Invalid request or webhook signature	Fix payload/config; do not retry blindly
401	Unauthenticated	Refresh session or require login
403	Authenticated but device/ownership/policy denied	Show specific recovery or authorization path
404	Resource/credential not found or not owned	Do not disclose ownership
409	Conflict or duplicate operation	Refresh state and retry safely
429	Rate limit	Back off with jitter
500/503	Server/provider failure	Show retry state; alert operations

Support-safe diagnostic bundle

- Request ID, timestamp, endpoint, client release, browser/OS, and HTTP status.
- Do not include account passwords, vault entries, access tokens, recovery kits, raw WebAuthn assertions, or screenshots of secret values.
- For billing, include provider transaction/subscription ID only after confirming it is not a secret credential.